

CISA Cybersecurity Incident and Vulnerability Response Playbook

Page 1 of 3 | Document ID: doc_en_11

Phase 1 & 2: Preparation, Incident Detection, and Initial Analysis

The CISA playbook outlines standardized operational procedures for responding to cybersecurity threats across institutional networks.

The response lifecycle comprises five distinct phases: Preparation, Detection & Analysis, Containment, Eradication & Recovery, and Post-Incident Review.

Upon detecting anomalous activity, the incident response team must validate the threat and assign an initial severity rating within 15 minutes.

High-severity incidents affecting critical operations or domain controllers must be escalated to executive leadership immediately.

CISA Cybersecurity Incident and Vulnerability Response Playbook

Page 2 of 3 | Document ID: doc_en_11

Phase 3: Containment Strategies and Forensic Evidence Preservation

Containment isolates compromised systems to prevent lateral movement while preserving volatile memory and network connections.

Investigators must use write-blocking hardware when acquiring physical hard drive bitstream images to prevent evidence alteration.

Forensic images and memory dumps must be verified immediately using SHA-256 cryptographic hashing to maintain integrity.

A formal Chain of Custody document must track every forensic artifact from point of acquisition through final regulatory reporting.

CISA Cybersecurity Incident and Vulnerability Response Playbook

Page 3 of 3 | Document ID: doc_en_11

Phase 4 & 5: Eradication, Recovery, and Post-Incident Lessons Learned

Eradication involves purging adversary footholds, resetting compromised enterprise credentials, and patching exploited vulnerabilities.

Restored systems must be connected to isolated monitoring segments for at least 72 hours of telemetry review before full production.

The incident response team must publish a final Root Cause Analysis (RCA) and Lessons Learned report within 14 days of closure.

Recommendations must update preventative defensive controls and firewall ingress rules to prevent recurrent exploitation.